

ETHICAL REPORT - LAB 11



VAPT Report

Ethical hacking for a vulnerable machine using various tools

Submitted By: Khushi Chadda

SAP ID: 70022300225

Roll No: D040

Class: BTech CE 'A'

1. Executive Summary

This report presents the results of the ethical hacking and vulnerability assessment activities performed as part of Labs 8 and 9.

The practical security testing was performed on Damn Vulnerable Web Application (DVWA), a deliberately vulnerable web application used for security testing and learning. During the assessment, the SQL Injection vulnerability was examined using the DVWA application and Burp Suite was used to observe and intercept HTTP requests.

The testing demonstrated that an improperly protected web application input can allow unintended interaction with the application's database. The SQL Injection module in DVWA successfully returned information associated with the selected user ID, demonstrating the vulnerable behavior. The Burp Suite screenshot also shows the HTTP request being captured for inspection.

Lab 9 complemented the practical assessment by studying the MITRE ATT&CK framework, which provides a structured way of describing attacker behavior through tactics, techniques, sub-techniques, and procedures.

The purpose of this combined report is to document the testing methodology, observations, evidence, security implications, and recommended mitigation measures.

2. Introduction

Vulnerability Assessment and Penetration Testing (VAPT) is a security testing process used to identify weaknesses in systems and applications and understand the possible security consequences of those weaknesses.

A penetration test report is important because it communicates the vulnerabilities discovered during testing, explains why they exist, describes their possible impact, and provides information that can be used for remediation. The Experiment 10 instructions specifically state that a VAPT report should provide technical teams with details about what is vulnerable, why it is vulnerable, who may be affected, and how the vulnerability can be exploited.

For this experiment, the practical assessment from Lab 8 and the security framework concepts from Lab 9 have been combined into a single report.

3. Objectives

The main objectives of the assessment were:

1. To understand the process of vulnerability assessment and penetration testing.
2. To configure and access a deliberately vulnerable web application.
3. To identify and demonstrate a SQL Injection vulnerability in DVWA.
4. To understand how HTTP requests can be captured and inspected using Burp Suite.
5. To observe the behavior of the vulnerable application during testing.
6. To document security findings in a structured VAPT report.
7. To understand how the MITRE ATT&CK framework describes attacker behavior.
8. To understand tactics, techniques, sub-techniques, and procedures used in cybersecurity analysis.
9. To identify suitable security measures for reducing the risk associated with vulnerable application inputs.

4. Scope of Assessment

The assessment was conducted in a controlled laboratory environment.

Target Application

Damn Vulnerable Web Application (DVWA)

Target Environment

A local DVWA instance was used for the practical security assessment.

The screenshot from Lab 8 shows DVWA running locally and displaying its database setup/status page. The environment includes a local web server and database configuration.

Security Testing Tools

- DVWA
- Burp Suite
- Web browser
- Local web server
- Database used by DVWA

Testing Focus

The practical testing documented in the supplied Lab 8 material focuses on:

SQL Injection

Lab 9 focuses on the MITRE ATT&CK framework and attacker behavior analysis rather than demonstrating another vulnerability.

5. Technologies and Tools Used

5.1 Damn Vulnerable Web Application (DVWA)

DVWA is a deliberately vulnerable web application used for security education and testing.

In Lab 8, DVWA was configured and accessed through the local environment. The setup page displayed the database setup and configuration information before testing was performed.

5.2 Burp Suite

Burp Suite was used to intercept and inspect HTTP communication between the browser and the DVWA application.

The Lab 8 screenshot shows Burp Suite's Proxy interface with an intercepted HTTP request to the DVWA SQL Injection page. This demonstrates how requests sent by the browser can be captured and examined during web application security testing.

5.3 MITRE ATT&CK

MITRE ATT&CK is a cybersecurity knowledge base used to describe real-world adversary behavior.

It organizes attacker activity into:

- Tactics
- Techniques
- Sub-techniques
- Procedures

Tactics describe why an attacker performs an action, while techniques describe how an attacker attempts to achieve a particular goal.

6. Methodology

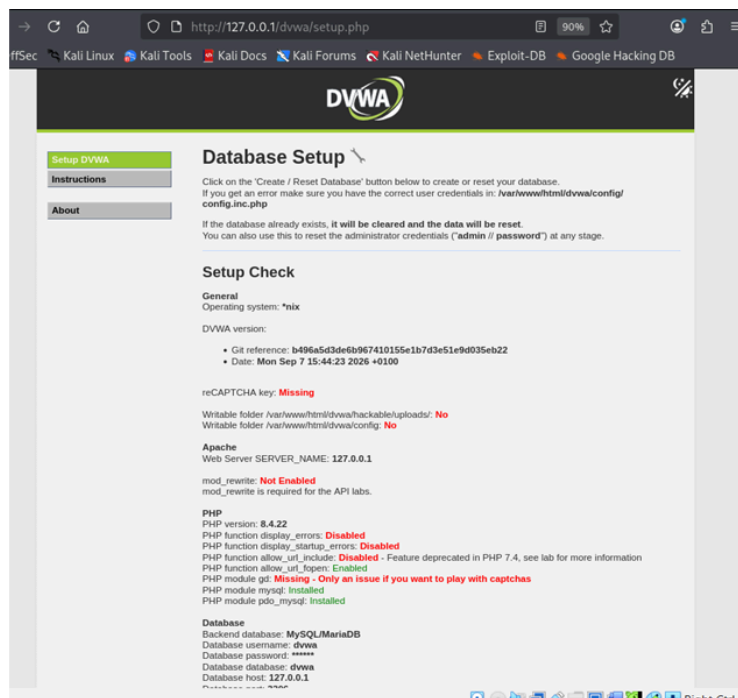
The assessment was performed using the following general methodology:

Environment Setup → Application Access → Vulnerability Identification → Request Interception → Vulnerability Demonstration → Observation → Security Analysis → Documentation

Step 1: Set up the vulnerable application

The DVWA application was configured in the local laboratory environment.

The database setup page was accessed to verify the application environment.



Step 2: Access DVWA

After the environment was configured, the DVWA login page was accessed.

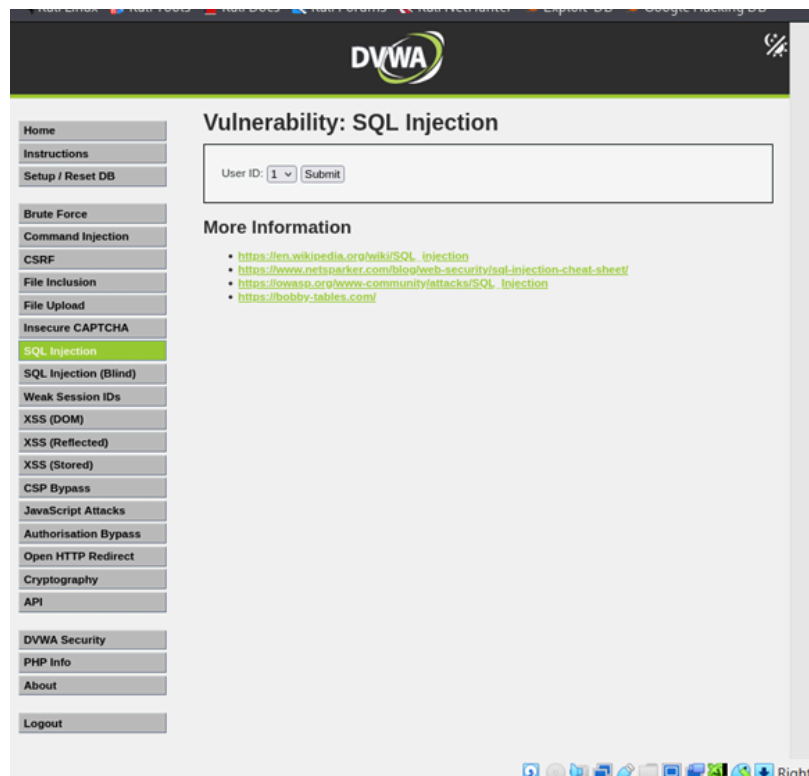
The Lab 8 screenshots show the DVWA interface with username and password fields.



Step 3: Access the SQL Injection module

The SQL Injection functionality was selected from the DVWA menu.

The page provides a User ID input field and a Submit button.



Step 4: Test the application input

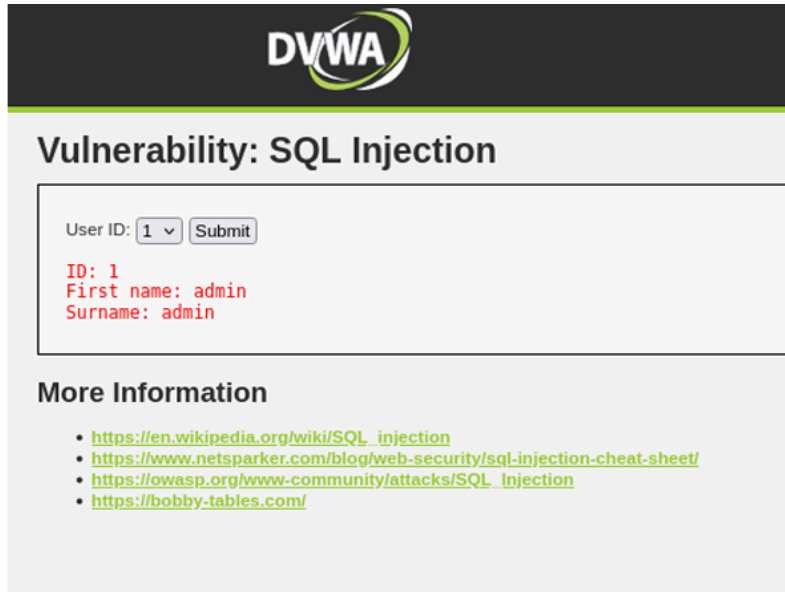
A user ID was submitted through the SQL Injection page.

The application processed the input and displayed information associated with the selected record.

The submitted result shown in the Lab 8 evidence includes:

- ID: 1
- First name: admin
- Surname: admin

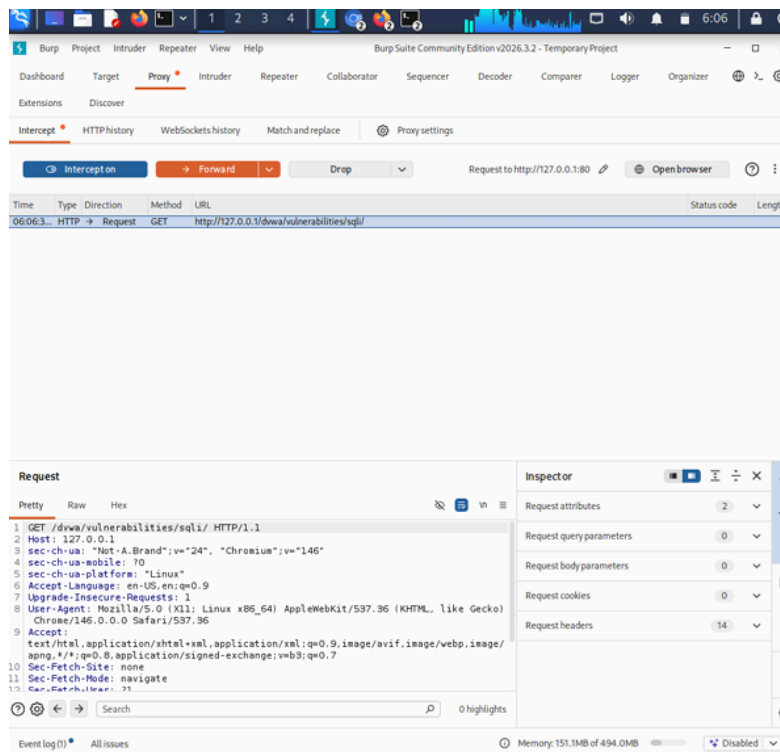
This demonstrates that the application retrieves database information based on the supplied input.



Step 5: Intercept the HTTP request using Burp Suite

Burp Suite was configured to intercept the request generated while interacting with the SQL Injection page.

The screenshot shows the request captured inside Burp Suite's Proxy interface. The request contains the DVWA SQL Injection endpoint and associated HTTP request information.



Step 6: Analyze the observation

The testing demonstrated that user-controlled input is processed by the application and results in database information being returned.

This behavior is characteristic of a SQL Injection testing scenario and indicates the importance of properly validating and safely handling database queries.

7. Finding 1 – SQL Injection

Finding Name

SQL Injection

Affected Component

DVWA – SQL Injection Module

Vulnerability Type

Web Application Injection Vulnerability

Description

SQL Injection occurs when an application incorporates user-controlled input into database queries without adequately protecting the query from manipulation.

In the DVWA environment, the SQL Injection functionality was tested through the User ID input field.

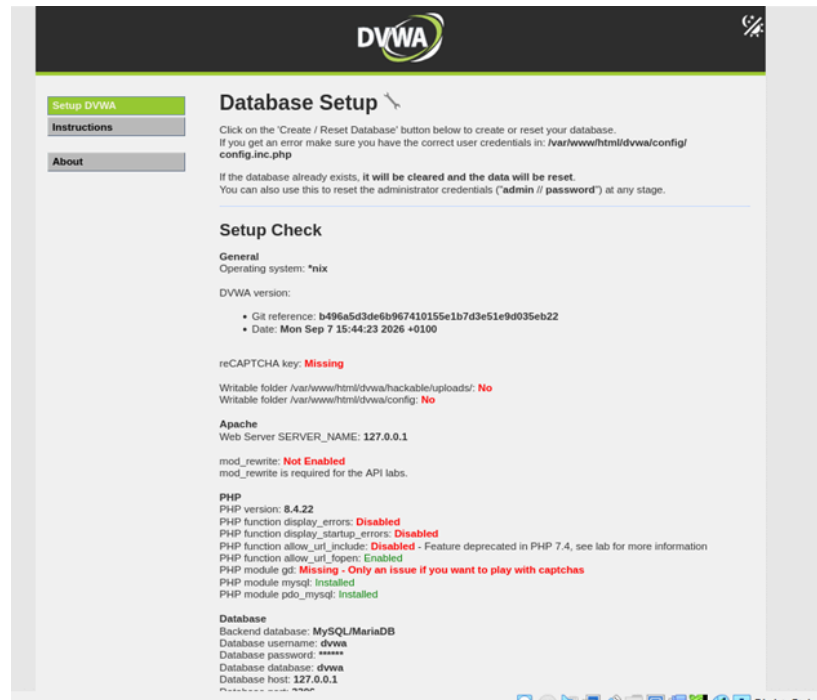
The application returned database information based on the supplied input. The screenshot shows the resulting record with **ID 1, First name "admin", and Surname "admin"**.

8. Evidence of SQL Injection Testing

The following evidence was obtained during the practical assessment:

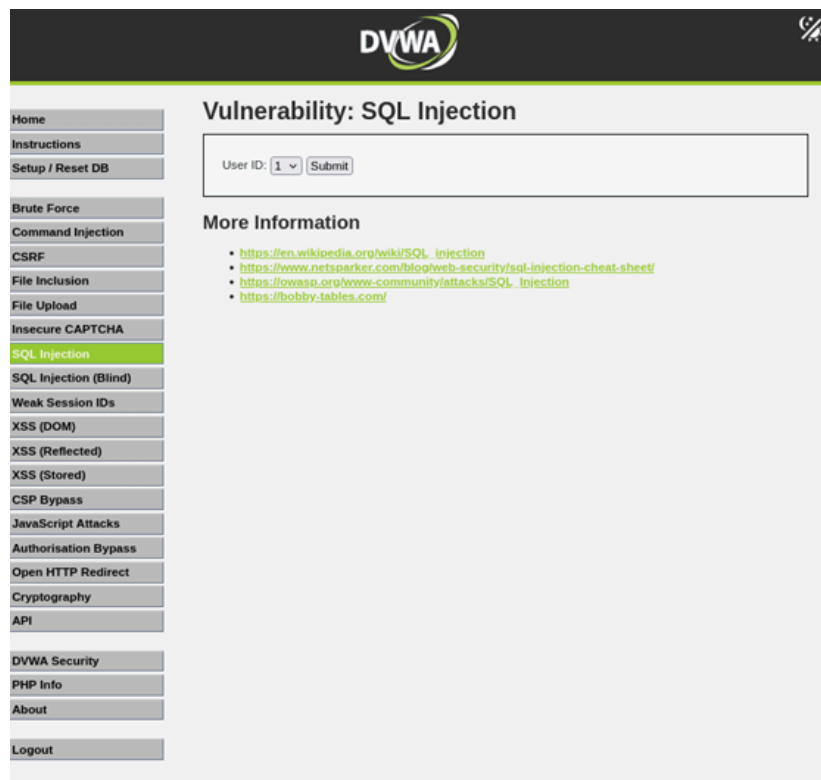
Evidence 1 – DVWA Setup

The DVWA setup page shows the local application and database configuration/status.



Evidence 2 – DVWA SQL Injection Page

The SQL Injection page shows the User ID input field and Submit button.



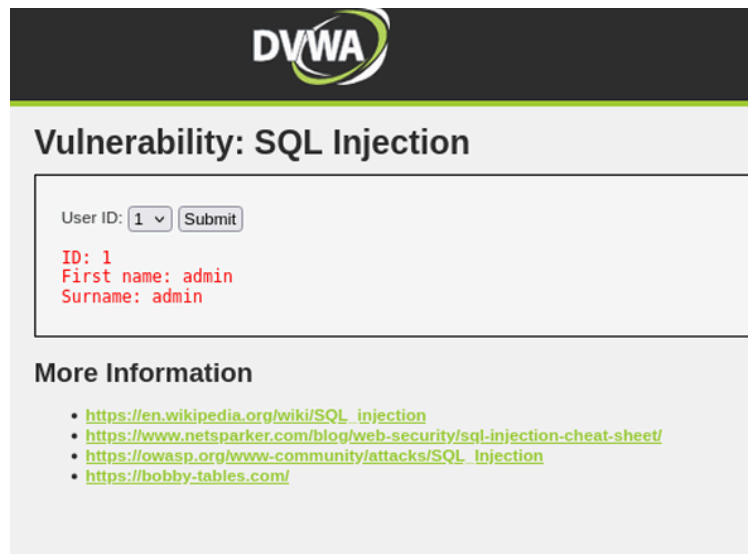
Evidence 3 – SQL Injection Result

The result displayed by DVWA contains the retrieved user information:

ID: 1

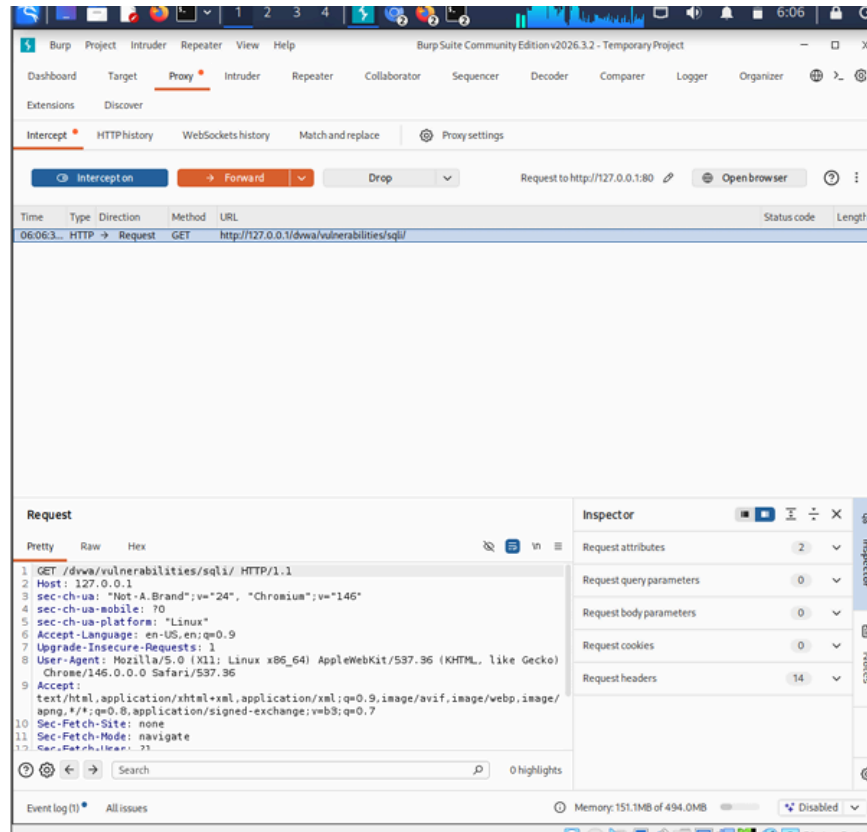
First name: admin

Surname: admin



Evidence 4 – Burp Suite Interception

Burp Suite captured the HTTP request generated while accessing the SQL Injection functionality.



9. Security Impact

If a similar SQL Injection vulnerability existed in a real application, an attacker could potentially manipulate database queries through application inputs.

Depending on the application's database permissions and implementation, SQL Injection can potentially lead to:

- Unauthorized access to database information
- Exposure of user information
- Modification of database records
- Deletion of database information
- Authentication-related attacks
- Further compromise of the application

The exact impact depends on the application's database privileges, query construction, input handling, and security controls.

For this laboratory exercise, the observed result demonstrates database information being returned through the vulnerable functionality.

10. Root Cause

The fundamental security concern associated with SQL Injection is unsafe handling of user-controlled input when constructing database queries.

Potential contributing factors include:

- Lack of proper input validation
- Unsafe construction of SQL queries
- Failure to use parameterized queries
- Excessive database privileges
- Insufficient security testing

11. Recommended Remediation

The following measures should be implemented to protect a real-world application against SQL Injection:

11.1 Use Parameterized Queries

Use prepared statements and parameterized queries instead of constructing SQL statements directly from user input.

11.2 Validate User Input

Validate input according to the expected data type and format.

For example, if the application expects a numeric User ID, it should validate that the supplied value follows the expected format.

11.3 Apply Least Privilege

The application's database account should have only the permissions required for its functionality.

11.4 Avoid Detailed Database Errors

Database errors should not expose internal database information to users.

11.5 Perform Regular Security Testing

Applications should be regularly assessed using vulnerability scanning, code review, and penetration testing.

11.6 Use Secure Coding Practices

Developers should follow secure development practices when handling database queries and user-controlled input.

12. MITRE ATT&CK Framework Analysis

Lab 9 studied the MITRE ATT&CK framework as a method for understanding attacker behavior.

The framework organizes adversary behavior into tactics, techniques, sub-techniques, and procedures.

The ATT&CK Matrix provides a visual organization of attacker objectives and techniques. The Lab 9 material describes example stages such as:

Initial Access → Execution → Persistence → Credential Access → Discovery → Lateral Movement → Collection → Exfiltration

It is important to note that these stages do not necessarily occur in exactly this order during every attack.

Reconnaissance	Resource Development	Initial Access	Execution	Persistence	Privilege Escalation	Stealth	Defense Impairment	Collection
12 techniques	9 techniques	11 techniques	20 techniques	22 techniques	13 techniques	30 techniques	18 techniques	17 techniques
Active Scanning (2)	Acquire Access	Content Injection	BITS Jobs	Account Manipulation (2)	Abuse Elevation Control Mechanism (3)	Disable or Modify System Firewall (3)	Adversary Lateral Movement (1)	Adversary Lateral Movement (1)
Gather Victim Host Information (4)	Acquire Infrastructure (3)	Drive-by Compromise	Cloud Administration Command	BITS Jobs	Access Token Manipulation (5)	Build Image on Host	Disable or Modify Tools (6)	Build Image on Host
Gather Victim Identity Information (3)	Compromise Accounts (3)	Exploit Public-Facing Application	Command and Scripting Interpreter (13)	Boot or Logon Autostart Execution (14)	Account Manipulation (7)	Debugger Evasion	Domain or Tenant Policy Modification (2)	Debugger Evasion
Gather Victim Network Information (3)	Compromise Infrastructure (3)	External Remote Services	Container Administration Command	Boot or Logon Initialization Scripts (3)	Boot or Logon Autostart Execution (14)	Deobfuscate/Decode Files or Information	Downgrade Attack	Deobfuscate/Decode Files or Information
Gather Victim Org Information (4)	Develop Capabilities (4)	Hardware Additions	Deploy Container	Cloud Application Integration	Boot or Logon Initialization Scripts (3)	Direct Volume Access	Exploitation for Defense Impairment	Exploitation for Defense Impairment
Phishing for Information (4)	Establish Accounts (3)	Phishing (4)	ESXi Administration Command	Compromise Host Software Binary	Create or Modify System Process (5)	Execution Guardrails (2)	File and Directory Permissions Modification (2)	Execution Guardrails (2)
Query Public AI Services	Generate Content (2)	Replication Through Removable Media	Exploitation for Client Execution	Create Account (3)	Domain or Tenant Policy Modification (2)	Exploitation for Stealth	Hide Artifacts (14)	Exploitation for Stealth
Search Closed Sources (2)	Obtain Capabilities (7)	Supply Chain Compromise (3)	Hijack Execution Flow (12)	Create or Modify System Process (5)	Escape to Host	Hide Artifacts (14)	Hijack Execution Flow (12)	Create or Modify System Process (5)
Search Open Technical Databases (5)	Stage Capabilities (3)	Trusted Relationship	Input Injection	Event Triggered Execution (18)	Exploitation for Privilege Escalation	Indicator Removal (3)	Indicator Removal (3)	Event Triggered Execution (18)
Search Open Websites/Domains (3)		Valid Accounts (4)	Inter-Process Communication (3)	Exclusive Control	Process Injection (12)	Masquerading (12)	Modify Cloud Compute Infrastructure (5)	Process Injection (12)
Search Threat Vendor Data		Wi-Fi Networks	Native API	External Remote Services	Scheduled Task/Job (3)	Obfuscated Files or Information (18)	Modify Cloud Resource Hierarchy	Scheduled Task/Job (3)
Search Victim-Owned Websites			Poisoned Pipeline Execution	Implant Internal Image	Scheduled Task/Job (3)	Pre-OS Boot (3)	Modify System Image (2)	Scheduled Task/Job (3)
			Scheduled Task/Job (3)	Serverless Execution		Process Injection (12)	Network	

13. ATT&CK Techniques Studied

13.1 Phishing – T1566

Tactic: Initial Access

Phishing involves using communication such as email or another message to trick a user into performing an action that can assist an attacker in gaining access.

The Lab 9 material describes examples such as malicious attachments and links.

13.2 Brute Force – T1110

Tactic: Credential Access

Brute Force involves repeatedly attempting different passwords or credentials to gain access to an account.

The Lab 9 document identifies sub-techniques including:

- Password Guessing
- Password Cracking
- Password Spraying
- Credential Stuffing

13.3 Command and Scripting Interpreter – T1059

Tactic: Execution

This technique involves using command-line tools or scripting environments to execute commands.

Examples discussed in Lab 9 include:

- PowerShell
- Windows Command Shell
- Unix Shell
- Python

The technique can be used legitimately for administration but can also be misused after an attacker gains access to a system.

14. Relationship Between VAPT and MITRE ATT&CK

The two laboratory activities provide complementary perspectives on cybersecurity.

The **VAPT activity** focuses on identifying and demonstrating a specific vulnerability in a controlled application environment.

The **MITRE ATT&CK activity** provides a structured framework for understanding how adversaries perform different activities.

Therefore, the combined work helps demonstrate both:

Vulnerability Identification
and
Adversary Behavior Analysis

MITRE ATT&CK can help security professionals understand attacker behavior, identify techniques, improve detection, analyze incidents, and test security controls.

15. Risk Analysis

Finding	Affected Area	Potential Impact	Risk Consideration
SQL Injection	DVWA SQL Injection module	Unauthorized database access or manipulation in a real application	Significant if present in a production application
Unsafe input handling	User-controlled database input	Database information may be exposed or manipulated	Requires remediation
Insufficient input validation	Web application input	Unexpected database query behavior	Requires secure input handling

The table describes the security implications of the observed vulnerability; it is not a quantitative risk score because the supplied laboratory material does not provide enough information for a formal CVSS calculation.

16. Overall Testing Results

The assessment successfully demonstrated the following:

1. DVWA was configured and accessed in the laboratory environment.
2. The SQL Injection functionality was identified.
3. User input was submitted through the vulnerable functionality.
4. The application returned database information associated with the supplied input.
5. Burp Suite was used to intercept and inspect the corresponding HTTP request.

6. The practical findings were documented as a web application vulnerability.
7. MITRE ATT&CK concepts were studied to understand attacker tactics and techniques.
8. Phishing, Brute Force, and Command and Scripting Interpreter were examined as examples of ATT&CK techniques.

17. Recommendations

Based on the assessment, the following security practices are recommended for real-world applications:

- Use prepared statements and parameterized SQL queries.
- Validate and sanitize user inputs.
- Apply least-privilege database permissions.
- Keep application and database components updated.
- Avoid exposing sensitive database errors.
- Conduct regular vulnerability assessments.
- Perform penetration testing before deploying applications.
- Monitor suspicious application requests.
- Use security logging and monitoring.
- Train developers in secure coding practices.
- Use frameworks such as MITRE ATT&CK to understand and analyze attacker behavior.

18. Conclusion

This combined assessment provided practical exposure to vulnerability assessment as well as structured analysis of cyberattack behavior.

In Lab 8, DVWA was used as a controlled vulnerable environment to demonstrate SQL Injection. The application accepted user input through its SQL Injection module and returned database information. Burp Suite was also used to intercept and inspect the HTTP request generated during the testing process.

Lab 9 introduced the MITRE ATT&CK framework, including tactics, techniques, sub-techniques, procedures, and the ATT&CK Matrix. Examples such as Phishing, Brute Force, and Command and Scripting Interpreter demonstrated how attacker behavior can be systematically described and analyzed.

The work demonstrates the importance of identifying vulnerabilities, understanding their potential security impact, documenting technical evidence, and recommending appropriate security controls. This follows the objective of Experiment 10, which requires the findings from Labs 8 and 9 to be presented as a structured VAPT report.